

ZAP by Checkmarx

Scanning Report # 3

Generated with  ZAP on Tue 11 Aug 2026, at 17:16:09

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Contents

- [About This Report](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
 - [Insights](#)
- [Alerts](#)
 - [Risk=Medium, Confidence=High \(5\)](#)
 - [Risk=Medium, Confidence=Medium \(1\)](#)
 - [Risk=Low, Confidence=Medium \(2\)](#)

- [Risk=Informational, Confidence=Medium \(2\)](#)
- [Appendix](#)
 - [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <http://localhost:3000>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: [User Confirmed](#), [High](#), [Medium](#), [Low](#)

Excluded: [User Confirmed](#), [High](#), [Medium](#), [Low](#), [False Positive](#)

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
Risk		User Confirmed	High	Medium	Low	Total
	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Medium	0 (0.0%)	5 (50.0%)	1 (10.0%)	0 (0.0%)	6 (60.0%)
	Low	0 (0.0%)	0 (0.0%)	2 (20.0%)	0 (0.0%)	2 (20.0%)
	Informational	0 (0.0%)	0 (0.0%)	2 (20.0%)	0 (0.0%)	2 (20.0%)
	1					
Total		0 (0.0%)	5 (50.0%)	5 (50.0%)	0 (0.0%)	10 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

	Risk				Informational
		High (= High)	Medium (>= Medium)	Low (>= Low)	(>= Informational)
http://localhost:3000	0	0	6	2	2
Site	0	(0)	(6)	(8)	(10)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
CSP: Failure to Define Directive with No Fallback	Medium	5 (50.0%)
CSP: script-src unsafe-eval	Medium	5 (50.0%)
CSP: script-src unsafe-inline	Medium	5 (50.0%)
Total		10

Alert type	Risk	Count
CSP: style-src unsafe-inline	Medium	5 (50.0%)
Content Security Policy (CSP) Header Not Set	Medium	5 (50.0%)
Missing Anti-clickjacking Header	Medium	2 (20.0%)
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	5 (50.0%)
X-Content-Type-Options Header Missing	Low	5 (50.0%)
Information Disclosure - Suspicious Comments	Informational	9 (90.0%)
Modern Web Application	Informational	5 (50.0%)
Total		10

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Medium	Exceeded Low		Percentage of memory used	88
Low	Warning		ZAP errors logged - see the zap.log file	4

Level	Reason	Site	Description	Statistic
			for details	
Low	Warning		ZAP warnings logged - see the zap.log file for details	64
Info	Informational	http://localhost:3000	Percentage of responses with status code 2xx	89 %
Info	Exceeded Low	http://localhost:3000	Percentage of responses with status code 4xx	10 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/javascript	33 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/css	6 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/html	60 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method GET	100 %
Info	Informational	http://localhost	Count of total endpoints	15

Level	Reason	Site	Description	Statistic
		st:3000		
Info	Informational	http://localhost:3000	Percentage of slow responses	2 %

Alerts

Risk=Medium, Confidence=High (5)

http://localhost:3000 (5)

CSP: Failure to Define Directive with No Fallback (1)

▶ GET http://localhost:3000

CSP: script-src unsafe-eval (1)

▶ GET http://localhost:3000

CSP: script-src unsafe-inline (1)

▶ GET http://localhost:3000

CSP: style-src unsafe-inline (1)

▶ GET http://localhost:3000

Content Security Policy (CSP) Header Not Set (1)

▶ GET http://localhost:3000

Risk=Medium, Confidence=Medium (1)

<http://localhost:3000> (1)

Missing Anti-clickjacking Header (1)

► GET <http://localhost:3000>

Risk=Low, Confidence=Medium (2)

<http://localhost:3000> (2)

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (1)

► GET <http://localhost:3000>

X-Content-Type-Options Header Missing (1)

► GET <http://localhost:3000>

Risk=Informational, Confidence=Medium (2)

<http://localhost:3000> (2)

Information Disclosure - Suspicious Comments (1)

► GET http://localhost:3000/_next/static/chunks/app-pages-internals.js

Modern Web Application (1)

► GET <http://localhost:3000>

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

CSP: Failure to Define Directive with No Fallback

Source	raised by a passive scanner (CSP)
CWE ID	693
WASC ID	15
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options

CSP: script-src unsafe-eval

Source	raised by a passive scanner (CSP)
CWE ID	693
WASC ID	15

Reference

- <https://www.w3.org/TR/CSP/>
- <https://caniuse.com/#search=content+security+policy>
- <https://content-security-policy.com/>
- <https://github.com/HtmlUnit/htmlunit-csp>
- <https://web.dev/articles/csp#resource-options>

CSP: script-src unsafe-inline

Source raised by a passive scanner ([CSP](#))

CWE ID [693](#)

WASC ID 15

Reference

- <https://www.w3.org/TR/CSP/>
- <https://caniuse.com/#search=content+security+policy>
- <https://content-security-policy.com/>
- <https://github.com/HtmlUnit/htmlunit-csp>
- <https://web.dev/articles/csp#resource-options>

CSP: style-src unsafe-inline

Source raised by a passive scanner ([CSP](#))

CWE ID [693](#)

WASC ID 15

- Reference**
- <https://www.w3.org/TR/CSP/>
 - <https://caniuse.com/#search=content+security+policy>
 - <https://content-security-policy.com/>
 - <https://github.com/HtmlUnit/htmlunit-csp>
 - <https://web.dev/articles/csp#resource-options>

Content Security Policy (CSP) Header Not Set

Source raised by a passive scanner ([Content Security Policy \(CSP\) Header Not Set](#))

CWE ID [693](#)

WASC ID 15

- Reference**
- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP>
 - https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
 - <https://www.w3.org/TR/CSP/>
 - <https://w3c.github.io/webappsec-csp/>
 - <https://web.dev/articles/csp>
 - <https://caniuse.com/#feat=contentsecuritypolicy>

- <https://content-security-policy.com/>

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)

Source	raised by a passive scanner (Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s))
CWE ID	497
WASC ID	13
Reference	▪ https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework ▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security-Headers

Information Disclosure - Suspicious Comments

Source	raised by a passive scanner (Information Disclosure - Suspicious Comments)
CWE ID	615
WASC ID	13

Modern Web Application

Source	raised by a passive scanner (Modern Web Application)
---------------	--